Table of Contents

CMMC Level 1 Access Control (AC) Labs — Student Completion Guide

This guide provides step-by-step instructions for completing all 12 Access Control labs. Each lab presents a real-world access control problem that you must identify and fix using Active Directory Users and Computers (ADUC) on the domain controller.

Table of Contents

1. Before You Begin
2. How to Connect to the Lab Environment
3. How to Open Active Directory Users and Computers
4. Understanding Your Pod
5. Module 1: Account Management (Labs L1.1 – L1.3)
6. Module 2: Joiners, Movers, and Leavers (Labs L2.1 – L2.3)
7. Module 3: Least Privilege and Access Control (Labs L3.1 – L3.3)
8. Module 4: Audit and Accountability (Labs L4.1 – L4.3)
9. Quick Reference: Where to Find Things in ADUC
10. Tips and Common Mistakes

Before You Begin

What You Need

- Your **Pod number** (your instructor will assign this, e.g., Pod01, Pod05, Pod12)
- Your **Guacamole login credentials** (your instructor will provide your username and password)
- A computer with a web browser (Chrome, Firefox, or Edge) — no special software needed

What You Will Be Doing

In these labs you will use **Active Directory Users and Computers (ADUC)** — the standard Windows tool for managing user accounts, groups, and organizational structure in a corporate network. You will find and fix access control violations that simulate real-world problems a cybersecurity analyst would encounter.

CMMC Context

These labs align with **CMMC Level 1 Access Control (AC)** requirements:

- **AC.L1-3.1.1** — Limit system access to authorized users
- **AC.L1-3.1.2** — Limit system access to the types of transactions and functions authorized users are permitted to execute
- **AC.L1-3.1.20** — Verify and control connections to external systems
- **AC.L1-3.1.22** — Control information posted or processed on publicly accessible systems

---

How to Connect to the Lab Environment

You will connect to the lab through **Apache Guacamole** — a web-based remote desktop gateway. There is nothing to install; everything runs in your web browser.

Step 1: Open the Guacamole Gateway

1. Open your web browser (Chrome, Firefox, or Edge)
2. Go to: **https://crc.guac.01.tcecure.com/#/**
3. You will see a login screen

Step 2: Log In with Your Student Credentials

1. Enter your **Username** — this matches your pod number:
   - Pod 01 → `student01`
   - Pod 02 → `student02`
   - Pod 05 → `student05`
   - Pod 12 → `student12`
   - *(and so on — the number matches your assigned pod)*
2. Enter your **Password** (provided by your instructor)
3. Click **Login**

Step 3: Connect to the Domain Controller

After logging in, you will see a list of available connections. Each student has two pre-configured connections:

Connection Name
PODXX-DC
PODXX-WS01

1. Click on **PODXX-DC** (where XX is your pod number, e.g., **POD03-DC**)
2. The remote desktop session will open directly in your browser — no extra login is needed (credentials are pre-configured)
3. Wait a few seconds for the Windows Server desktop to appear

> **Tip:** To return to the Guacamole home screen (for example, to switch connections), press **Ctrl+Alt+Shift** to open the Guacamole side menu, then click **Home**.

You should now see the Windows Server desktop in your browser.

How to Open Active Directory Users and Computers

On the server desktop, double-click the **Active Directory Users and Computers** shortcut.

You should now see the ADUC window with a tree structure on the left side.

Important — do not launch ADUC any other way. Your account has permission over your own pod only, and it is deliberately not an administrator of the domain controller (all 20 pods share that server). If you start ADUC from **Server Manager → Tools**, from `dsa.msc`, or by adding the snap-in to a blank MMC console, Windows tries to launch it elevated and shows a **User Account Control** prompt asking for an administrator username and password. Your student account is not an administrator, so entering it there is always rejected — that is expected and does not mean your password is wrong. Click **No** and use the desktop shortcut instead.

Alternative method (if the shortcut is missing):

1. Press **Windows key + R** to open the Run dialog
2. Paste `cmd /c "set __COMPAT_LAYER=RunAsInvoker&& start "" mmc.exe dsa.msc"` and press Enter

Everything in these labs can also be done from **PowerShell** (each lab below lists the commands), which never prompts for elevation.

Understanding Your Pod

Your instructor assigned you a **Pod number**. Everything you work with is prefixed with your pod number to keep your work separate from other students.

For example, if you are **Pod 03**:

- Your users are named like `P03-hr.user1`, `P03-fin.user1`, `P03-sales.user1`
- Your security groups are named like `P03-SG-ACS-Finance`, `P03-SG-ACS-HR`
- Your organizational unit (folder) is **Pod03** under the **Students** OU

Your Pod's Folder Structure in ADUC

Navigate to your pod by expanding the tree on the left side of ADUC:

```
acs-p01.local
  └── Students
        └── Pod03          <-- Your pod (replace 03 with your number)
              ├── Users
              │     ├── Admins      (IT admin accounts)
              │     └── Staff       (Regular employee accounts)
              ├── Groups
              │     ├── Security    (Security groups like P03-SG-ACS-
Finance)
              │     └── Distribution
              ├── Resources
              │     ├── Departments
              │     │     ├── Executive
              │     │     ├── IT
              │     │     ├── Finance
              │     │     ├── HR
              │     │     ├── Consulting
              │     │     └── Sales
              │     └── Computers
              │           ├── Workstations
              │           └── Servers
              └── Policies
```

Your Pod's User Accounts

Username
PXX-ceo.acs
PXX-it.admin
PXX-it.helpdesk
PXX-fin.user1
PXX-hr.user1
PXX-consult.user1
PXX-sales.user1

(Replace PXX with your pod prefix, e.g., P03)

Module 1: Account Management

Module 1 focuses on identifying and remediating unauthorized or incorrect account access. These are the most common access control violations in real organizations.

Lab L1.1 — Terminated Employee Still Has Active Access

Scenario: A former employee (`PXX-ex.employee`) was terminated but their account was never disabled. They still have an active account with access to the Finance security group and All-Staff. This is a critical security violation — terminated employees should have their access removed immediately.

Your Task: Find the terminated employee's account and disable it.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Users → Staff**
2. Look for the user account named **PXX-ex.employee** (e.g., `P03-ex.employee`)
3. Double-click on the account to open its properties
4. Notice that the **Description** field says: *"L1.1: Terminated user still enabled with Finance access"*
5. Look at the **Account** tab — the account is currently **enabled** (the checkbox "Account is disabled" is NOT checked)
6. **To fix this:** Check the box that says **"Account is disabled"**
7. Click **OK** to save

Why This Matters: CMMC AC.L1-3.1.1 requires that system access is limited to authorized users. A terminated employee is no longer authorized.

Bonus (Optional): You should also remove the user from the Finance and All-Staff groups:

1. Go to the **Member Of** tab in the user's properties
2. Select **PXX-SG-ACS-Finance** and click **Remove**
3. Select **PXX-SG-ACS-All-Staff** and click **Remove**
4. Click **OK**

Lab L1.2 — HR User Has Unauthorized Finance Access

Scenario: An HR employee (`PXX-hr.user1`) has been mistakenly added to the Finance security group. HR staff should only have access to HR resources — they should not be able to access financial data.

Your Task: Remove the HR user from the Finance group.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Users → Staff**
2. Find the user **PXX-hr.user1** and double-click to open properties

3. Notice the **Description** says: *"L1.2: HR user mistakenly in Finance group"*
4. Click the **Member Of** tab
5. You should see the user is a member of:
   - PXX-SG-ACS-HR (correct — they work in HR)
   - PXX-SG-ACS-All-Staff (correct — all employees are in this group)
   - **PXX-SG-ACS-Finance** (INCORRECT — this is the problem)
6. Select **PXX-SG-ACS-Finance** in the list
7. Click the **Remove** button
8. Click **Yes** to confirm
9. Click **OK** to save

Why This Matters: The principle of least privilege means users should only have access to the resources they need for their job. An HR employee does not need Finance access.

Lab L1.3 — Helpdesk Technician Has IT-Admins Privileges

Scenario: The helpdesk technician (`PXX-it.helpdesk`) has been incorrectly added to the IT-Admins security group. Helpdesk staff should have limited IT support access, not full administrator-level privileges.

Your Task: Remove the helpdesk user from the IT-Admins group.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Users → Admins**
2. Find the user **PXX-it.helpdesk** and double-click to open properties
3. Notice the **Description** says: *"L1.3: Helpdesk incorrectly given IT-Admins privileges"*
4. Click the **Member Of** tab
5. You should see the user is a member of:
   - PXX-SG-ACS-IT (correct — they are IT staff)
   - PXX-SG-ACS-Helpdesk (correct — they are helpdesk)
   - **PXX-SG-ACS-IT-Admins** (INCORRECT — helpdesk should not have admin access)
6. Select **PXX-SG-ACS-IT-Admins**
7. Click **Remove**
8. Click **Yes** to confirm
9. Click **OK** to save

Why This Matters: Giving helpdesk staff full admin access violates least privilege. If a helpdesk account is compromised, the attacker would have full admin access to all IT systems.

Module 2: Joiners, Movers, and Leavers

Module 2 focuses on the lifecycle of user accounts — when people join the organization, change roles, or leave.

Lab L2.1 — New Hire Account Not Created (Joiner)

Scenario: HR has approved a new employee named `new.user1` to join the organization. The CEO's account has a note about this approval (check the Description field on `PXX-ceo.acs`). However, the IT team has not yet created the account. This is a compliance gap — approved users should be provisioned in a timely manner.

Your Task: Create the new user account.

Step-by-Step Instructions:

1. First, verify the approval: Navigate to **Users → Staff** and double-click **PXX-ceo.acs**
2. Check the **Description** field — it says: *"L2.1: HR approved new.user1 - account not yet created"*
3. Close the CEO's properties
4. Now create the new account: Right-click on the **Staff** OU (under Users)
5. Select **New → User**
6. Fill in the fields:
   - **First name:** New
   - **Last name:** User1
   - **User logon name:** `PXX-new.user1` (replace PXX with your pod prefix, e.g., `P03-new.user1`)
7. Click **Next**
8. Enter a password (use the lab password your instructor provided)
9. Uncheck **"User must change password at next logon"** (for lab purposes)
10. Click **Next**, then **Finish**
11. Now add the user to the appropriate group:
    - Double-click the new user you just created
    - Go to the **Member Of** tab
    - Click **Add**

- Type `PXX-SG-ACS-All-Staff` and click **Check Names**, then **OK**
- Click **OK** to save

Why This Matters: Failing to provision approved accounts can delay onboarding and indicates a breakdown in the identity management process.

Lab L2.2 — Role Change Without Access Update (Mover)

Scenario: A consultant (`PXX-consult.user1`) has transferred from the Consulting department to the Sales department. Their new Sales access was added, but their old Consulting access was never removed. This means they have access to both departments' resources when they should only have Sales access now.

Your Task: Remove the user's old Consulting group membership.

Step-by-Step Instructions:

1. In ADUC, navigate to: **Users → Staff**
2. Find **PXX-consult.user1** and double-click to open properties
3. Check the **Description**: *"L2.2: Mover - old Consulting access not removed after role change"*
4. Click the **Member Of** tab
5. You should see:
   - PXX-SG-ACS-Sales (correct — their new role)
   - **PXX-SG-ACS-Consulting** (INCORRECT — old role, should be removed)
   - PXX-SG-ACS-All-Staff (correct)
6. Select **PXX-SG-ACS-Consulting**
7. Click **Remove**
8. Click **Yes** to confirm
9. Click **OK** to save

Why This Matters: When employees change roles, their old access must be revoked. This is called "access creep" — over time, users accumulate more access than they need, creating security risks.

Lab L2.3 — Departed Employee Not Properly Offboarded (Leaver)

Scenario: A finance employee (`PXX-fin.user1`) has left the organization, but their account was not properly offboarded. The account is still enabled and still has Finance group membership. Proper offboarding requires: (1) disabling the account, (2) removing all group memberships, and (3) moving the account to the Terminated OU.

Your Task: Perform a complete offboarding of this user account.

Step-by-Step Instructions:

Step A — Disable the account:

1. Navigate to: **Users → Staff**
2. Find **PXX-fin.user1** and double-click to open properties
3. Check the **Description**: *"L2.3: Leaver - should be disabled, de-grouped, moved to Terminated OU"*
4. Go to the **Account** tab
5. Check the box **"Account is disabled"**
6. Click **Apply** (don't close yet)

Step B — Remove all group memberships:

1. Click the **Member Of** tab
2. Select **PXX-SG-ACS-Finance** and click **Remove** → **Yes**
3. Select **PXX-SG-ACS-All-Staff** and click **Remove** → **Yes**
4. Click **Apply**

Step C — Move the account to the Terminated OU:

1. Click **OK** to close the properties window
2. Right-click on **PXX-fin.user1** in the list
3. Select **Move...**
4. In the Move dialog, navigate to: **acs-p01.local → Students → PodXX → Users → Terminated**
   - If the **Terminated** OU already exists, select it
   - If it does NOT exist, you need to create it first:
     i. Right-click on the **Users** OU (under your PodXX)
     ii. Select **New → Organizational Unit**
     iii. Name it `Terminated`
     iv. Click **OK**
     v. Then try the Move operation again
5. Click **OK** to complete the move

Why This Matters: Improper offboarding is one of the most common security gaps. Former employees with active accounts can still access company resources, creating a major insider threat risk.

Module 3: Least Privilege and Access Control

Module 3 focuses on the principle of least privilege — ensuring users have only the minimum access they need to do their jobs.

Lab L3.1 — User in Wrong Organizational Unit

Scenario: A sales employee (`PXX-sales.user1`) has been placed in the **Executive** department OU instead of the **Sales** department OU where they belong. Being in the wrong OU could give them access to executive-level resources through OU-based group policies.

Your Task: Move the user back to the correct department OU.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Resources → Departments → Executive**
2. You should see **PXX-sales.user1** in this OU (they should NOT be here)
3. Right-click on **PXX-sales.user1**
4. Select **Move...**
5. Navigate to: **acs-p01.local → Students → PodXX → Resources → Departments → Sales**
6. Click **OK**
7. Verify: Navigate to **Resources → Departments → Sales** and confirm the user is now there

   Important: the account must end up in the **Sales** OU. Moving it to `Users → Staff` (or any other OU) will not pass verification — the check requires `OU=Sales` in the account's distinguished name.

Why This Matters: OU placement determines which group policies and access controls apply to a user. A user in the wrong OU may receive access they are not authorized to have.

Lab L3.2 — Over-Permissioned Group Nesting

Scenario: The **All-Staff** security group has been nested inside the **IT-Admins** security group. This means every single employee in the organization now has IT administrator-level access — a massive security violation.

Your Task: Remove the All-Staff group from IT-Admins.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Groups → Security**
2. Find **PXX-SG-ACS-IT-Admins** and double-click to open properties
3. Click the **Members** tab

4. You should see:
   - PXX-it.admin (correct — IT admin should be here)
   - **PXX-SG-ACS-All-Staff** (INCORRECT — this is a group containing ALL employees)
5. Select **PXX-SG-ACS-All-Staff**
6. Click **Remove**
7. Click **Yes** to confirm
8. Click **OK** to save

Why This Matters: Group nesting can accidentally give hundreds of users access they should never have. This is why regular access reviews are required under CMMC.

Lab L3.3 — Delegation of Password Reset Authority

Scenario: The helpdesk technician (`PXX-it.helpdesk`) needs the ability to reset passwords for users in the Staff OU — but without having full IT-Admins access. Currently, the helpdesk account description mentions this delegation needs to be configured.

Your Task: Delegate the "Reset Password" permission for the Staff OU to the helpdesk user.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Users → Staff**
2. Right-click on the **Staff** OU
3. Select **Delegate Control...**
4. The Delegation of Control Wizard will open — click **Next**
5. Click **Add** to select who to delegate to
6. Type `PXX-it.helpdesk` (e.g., `P03-it.helpdesk`) and click **Check Names**
7. Click **OK**, then **Next**
8. In the tasks list, check the box for **"Reset user passwords and force password change at next logon"**
9. Click **Next**, then **Finish**

Verification: To verify the delegation was applied:

1. Click **View** in the ADUC menu bar
2. Select **Advanced Features** (if not already checked)
3. Right-click the **Staff** OU → **Properties**
4. Click the **Security** tab

5. You should see `PXX-it.helpdesk` listed with "Reset Password" permissions

Why This Matters: Instead of giving helpdesk staff full admin access (which violates least privilege), delegation allows them to perform specific tasks — like resetting passwords — without unnecessary privileges.

Module 4: Audit and Accountability

Module 4 focuses on monitoring, reviewing, and documenting access control activities.

Lab L4.1 — Contractor Account Without Expiration

Scenario: A contractor (`PXX-contractor.user1`) has an active account with no expiration date set. Company policy requires that all contractor and temporary accounts must have an expiration date to ensure they are automatically disabled when the contract ends.

Your Task: Set an expiration date on the contractor's account.

Step-by-Step Instructions:

1. In ADUC, navigate to: **acs-p01.local → Students → PodXX → Users → Staff**
2. Find **PXX-contractor.user1** and double-click to open properties
3. Check the **Description**: *"L4.1: Contractor access should be disabled/expired per policy"*
4. Click the **Account** tab
5. Look at the bottom of the tab — find **"Account expires"**
6. It is currently set to **"Never"**
7. Select **"End of:"** and set a date (for example, 30 days from today or an end date provided by your instructor)
8. Click **OK** to save

Optional — Also disable the account immediately:

1. If your instructor directs you to disable the account now (simulating an expired contract), check **"Account is disabled"** on the Account tab
2. Click **OK** to save

Why This Matters: Contractor accounts without expiration dates are a common audit finding. If a contractor leaves and no one remembers to disable their account, they retain access indefinitely.

Lab L4.2 — Missing Audit Evidence (Empty Evidence Folder)

Scenario: An access review was supposed to be conducted and documented in the evidence folder `C:\CyberLab\PodXX\Lab4-2` on the domain controller. However, the folder is empty — no evidence was collected. You need to perform a basic access review and document the results.

Your Task: Conduct a basic access review and save the evidence.

Step-by-Step Instructions:

1. Open **PowerShell** on the domain controller:
   - Click the **Start** button
   - Type `PowerShell` and click **Windows PowerShell**
2. Run the following command to export the access review to **`review.csv`** (replace `Pod03` with your pod, e.g. `Pod07`):

   ```
   Get-ADUser -Filter {Enabled -eq $true} -SearchBase
   "OU=Pod03,OU=Students,DC=acs-p01,DC=local" -Properties MemberOf |
   Select-Object Name, SamAccountName, Enabled | Export-Csv "C:\
   CyberLab\Pod03\Lab4-2\review.csv" -NoTypeInformation
   ```

   The file must be named `review.csv` and live in `C:\CyberLab\PodXX\Lab4-2\`. Verification looks for that exact name and requires it to be non-empty; any other file name will not pass.
3. *(Optional supporting evidence)* export group memberships alongside it:

   ```
   Get-ADGroup -Filter * -SearchBase "OU=Pod03,OU=Students,DC=acs-
   p01,DC=local" | ForEach-Object { $group = $_.Name; Get-
   ADGroupMember $_ -ErrorAction SilentlyContinue | Select-Object
   @{N='Group';E={$group}}, Name, SamAccountName } | Export-Csv "C:\
   CyberLab\Pod03\Lab4-2\group_memberships.csv" -NoTypeInformation
   ```

4. Verify the file was created and is not empty:

   ```
   Get-ChildItem "C:\CyberLab\Pod03\Lab4-2"
   ```

   You must see `review.csv` with a size greater than 0.

Why This Matters: CMMC requires organizations to maintain evidence of access reviews. An empty evidence folder means the review was never conducted — a compliance failure.

Lab L4.3 — Incomplete Audit Evidence

Scenario: An access review was partially completed — there is a file in `C:\CyberLab\PodXX\Lab4-3` but it only contains a placeholder. You need to complete the review with actual data.

Your Task: Replace the placeholder with real audit evidence.

Step-by-Step Instructions:

1. First, check what exists in the evidence folder:

   ```
   Get-ChildItem "C:\CyberLab\Pod03\Lab4-3"
   Get-Content "C:\CyberLab\Pod03\Lab4-3\enabled_users.csv"
   ```

   You will see the file contains only "placeholder" — not real data.

2. Replace with a real export of enabled users:

   ```
   Get-ADUser -Filter {Enabled -eq $true} -SearchBase
   "OU=Pod03,OU=Students,DC=acs-p01,DC=local" -Properties MemberOf,
   Description | Select-Object Name, SamAccountName, Enabled,
   Description | Export-Csv "C:\CyberLab\Pod03\Lab4-3\
   enabled_users.csv" -NoTypeInformation -Force
   ```

3. Add a group membership report:

   ```
   Get-ADGroup -Filter * -SearchBase "OU=Pod03,OU=Students,DC=acs-
   p01,DC=local" | ForEach-Object { $group = $_.Name; Get-
   ADGroupMember $_ -ErrorAction SilentlyContinue | Select-Object
   @{N='Group';E={$group}}, Name, SamAccountName } | Export-Csv "C:\
   CyberLab\Pod03\Lab4-3\group_memberships.csv" -NoTypeInformation
   ```

4. Add a review summary document (every file in `Lab4-3` must be non-empty — an empty file anywhere in the folder fails the check):

   ```
   $date = Get-Date -Format "yyyy-MM-dd"
   $summary = @"
   Access Control Review - Pod03
   Date: $date
   Reviewer: [Your Name]

   Findings:
   - All enabled accounts have been reviewed
   - Group memberships documented in group_memberships.csv
   - Enabled user list documented in enabled_users.csv

   Status: Review Complete
   "@
   Set-Content "C:\CyberLab\Pod03\Lab4-3\review_summary.txt" $summary
   ```

5. Verify all files are present:

```
Get-ChildItem "C:\CyberLab\Pod03\Lab4-3"
```

You should see: `enabled_users.csv`, `group_memberships.csv`, and `review_summary.txt`

Why This Matters: Incomplete documentation is treated the same as no documentation during an audit. Evidence must be thorough and contain real, verifiable data.

Quick Reference: Where to Find Things

What You Need
Your pod's user accounts
Your pod's security groups
A user's group memberships
A group's members
Disable an account
Move a user to a different OU
Set account expiration
Create a new user
Delegate permissions
Evidence folders

Tips and Common Mistakes

Do's

- **Always check the Description field** on user accounts — it contains hints about what the problem is
- **Double-check your pod number** before making changes — you don't want to modify another pod's accounts
- **Click Apply** before switching tabs in the user properties dialog to save changes as you go
- **Work through the labs in order** — some labs build on concepts from earlier ones
- **Take screenshots** of your changes if your instructor requires evidence of completion

Don'ts

- **Don't delete user accounts** unless specifically instructed — disable them instead

- **Don't modify accounts outside your pod** — only touch accounts that start with your prefix (e.g., P03-)
- **Don't change passwords** on existing accounts unless the lab specifically asks you to
- **Don't close ADUC between labs** — keep it open and use it for all 12 labs
- **Don't skip the verification step** — after making a change, always confirm it took effect

If Something Goes Wrong

- If you accidentally modify the wrong account, tell your instructor — they can reset your pod
- If you can't find a user account, make sure you are looking in the correct OU (Staff vs. Admins)
- If a command in PowerShell gives an error, check that you replaced `PodXX` and `PXX` with your actual pod number
- If ADUC won't open, use the **Active Directory Users and Computers** desktop shortcut — do not use `dsa.msc` or Server Manager → Tools, which ask for administrator credentials your student account does not have

---

Lab Completion Checklist

Use this checklist to track your progress:

Lab
L1.1
L1.2
L1.3
L2.1
L2.2
L2.3
L3.1
L3.2
L3.3
L4.1
L4.2
L4.3